Network Services

Chapter 24: DNS/BIND

Interlude: Security

Chapter 25: Firewalls: iptables or nftables with firewalld frontend

Chapter 26: Apache

Chapter 24: DNS/BIND: Tracking Domain Names and Addresses

- As we saw earlier, DNS maps domain names to IP addresses
  - and vice versa, IP addresses to domain names
- Specifies protocol used to exchange information
- *Nameservers* work with clients (*resolvers*) to distribute *resource records* describing host information
- BIND is a popular open-source implementation

Introduction/Review

- DNS database is
  - hierarchical, distributed, replicated
  - secure, flexible, fast
- Utilities `host` and `dig` query DNS servers
- Root domain is ., fully qualified domain name (FQDN) ends in .
- Resolver takes host name, appends domains in search list and passes FQDNs to DNS
  - Search list in /etc/resolv.conf

Zones and Queries

- Domains are grouped into zones
  - DNS server is responsible (authoritative) for all domains in a zone
  - DNS server has pointers to DNS servers responsible for zones immediately below it
- Iterative query: returns IP address or name of DNS server authoritative for domain
  - used primarily by name servers
- Recursive query: returns IP address

Types of DNS Servers

- Primary master server
  - holds master copy of zone data
- Slave server
  - holds authoritative copy of zone data
- DNS cache or caching-only server
  - holds non-authoritative data

Resource Records

- Kept in zone files named in `named.conf` file
- Record fields
  - Name: domain name or IP address
    - if blank, inherits from previous record in same file
  - TTL: (generally optional) time to live (seconds)
  - Class: IN for internet
  - Type: record type (A, PTR, etc.)
  - Data: depends on record type

Resource Records

- A: IP4 Address for name
- CNAME: Canonical name (alias)
- MX: Mail Exchange for email for domain
- NS: Nameserver
- PTR: Pointer maps IP address to domain name
- SOA: Start of Authority defines zone
- TXT: Text – associates character string with domain

Setting Up DNS

- Install `bind`, `bind-utils`, `bind-chroot` (if want to run BIND in `chroot` jail)
- Configure `named` to start in multiuser mode
- If using firewall, open TCP and UDP port 53
- Configuration information is in /etc/named.conf
- External systems will only see if you have parent DNS server that delegates to you

/etc/named.conf

- Establishes server as master, slave, or cache-only name server
- Specifies zones over which server has authority
- Specifies which files to read for more details

Setting Up DNS Server

- Set up a zone for forward lookups and another zone for reverse lookups
- Add records to the zones for the things you want the DNS server to store
  - records for each host whose name you are defining
    - and reverse lookup for each
- See text example for more details

Sample named.conf

```
options {
listen-on port 53 { 127.0.0.1; 192.168.3.200; };
directory       "/var/named";
dump-file       "/var/named/data/cache_dump.db";
statistics-file "/var/named/data/named_stats.txt";
memstatistics-file
"/var/named/data/named_mem_stats.txt";
recursing-file  "/var/named/data/named.recursing";
secroots-file   "/var/named/data/named.secroots";
allow-query     { localhost; 192.168.3.0/24; };
recursion yes;
...
bindkeys-file "/etc/named.root.key";
managed-keys-directory "/var/named/dynamic";
pid-file "/run/named/named.pid";
session-keyfile "/run/named/session.key";
};

zone "." IN {
type hint;
file "named.ca";
};

include "/etc/named.rfc1912.zones";
include "/etc/named.root.key";
include "/etc/named/named.conf.local";
```

Sample named.conf.local

```
zone "infoteach.ca" {
    type master;
    file "/etc/named/zones/db.infoteach.ca"; # zone file path
};

zone "3.168.192.in-addr.arpa" {
    type master;
    file "/etc/named/zones/db.192.168.3";  # 192.168.3.0/24 subnet
};
```

Sample db.infoteach.ca

```
$TTL    604800
@       IN      SOA     services.okd4.infoteach.ca. admin.okd4.infoteach.ca. (
                1       ; Serial
           604800       ; Refresh
            86400       ; Retry
          2419200       ; Expire
           604800       ; Negative Cache TTL
)
   IN      NS      services.okd4.infoteach.ca.
services.okd4          IN      A       192.168.3.200
bootstrap.okd4         IN      A       192.168.3.230
control-plane-1.okd4   IN      A       192.168.3.201
control-plane-2.okd4   IN      A       192.168.3.202
control-plane-3.okd4   IN      A       192.168.3.203
compute-1.okd4         IN      A       192.168.3.204
compute-2.okd4         IN      A       192.168.3.205
...
; OpenShift internal cluster IPs - A records
api.okd4    IN    A    192.168.3.200
api-int.okd4    IN    A    192.168.3.200
*.apps.okd4    IN    A    192.168.3.200

okd4   IN CNAME services.okd4
```

Sample db.192.168.3

```
$TTL    604800
@       IN      SOA     services.okd4.infoteach.ca. admin.okd4.infoteach.ca. (
                6     ; Serial
           604800     ; Refresh
            86400     ; Retry
          2419200     ; Expire
           604800     ; Negative Cache TTL
)

   IN      NS      services.okd4.infoteach.ca.

200    IN    PTR    services.okd4.infoteach.ca.

; OpenShift Container Platform Cluster - PTR records
230    IN    PTR    bootstrap.okd4.infoteach.ca.
201    IN    PTR    control-plane-1.okd4.infoteach.ca.
202    IN    PTR    control-plane-2.okd4.infoteach.ca.
203    IN    PTR    control-plane-3.okd4.infoteach.ca.
204    IN    PTR    compute-1.okd4.infoteach.ca.
205    IN    PTR    compute-2.okd4.infoteach.ca

200    IN    PTR    api.okd4.infoteach.ca.
200    IN    PTR    api-int.okd4.infoteach.ca.
```

Chapter 25: iptables: Setting Up a Firewall

- The iptables utility builds and manipulates network packet filtering rules in Linux kernel
  - Can protect system from malicious users
  - Also set up NAT (Network Address Translation)
    - allow multiple users to share Internet connection
  - Provides connection tracking to handle packets based on state of their connection
- Text covers fundamentals only
- First a discussion of security at a higher level

Managing Security Risks

- What are the risks
- Who are the risks

What are the Risks

- Theft
  - steal information for personal gain
- Sabotage
  - destroy files, servers
  - alter files
- Denial of Service
  - virus attacks
  - slow down systems

Who are the risks

- Staff in Organization
- Competitors / Vendors / Clients
- Hackers / Thieves
- Viruses

Security: Risk vs Cost

- What is the cost of a security breach
- What is the cost to prevent a breach
- How to balance these two costs

Security Costs

- Every Risk has a Cost
- The Risk Cost sets the limits on spending
- Better protection costs more
  - Diminishing returns
- Security is a relative concept

What is the cost of a security breach

- This is the critical concept
- You only need so much security, after some point, additional security is a waste
- Up until that point, you need as much security as you can put in
- example: Cost of a Virus Infection

Simple Case Study: A Virus Infection

- Installs on many workstations
- Sits in files on servers
- Sits in files in email
- Sits in files on backup and other medial
- Triggers and destroys workstation configuration

The Cost of a Virus

- Lost customers
- User downtime while workstation/server is not available
- User time to repair damaged files
- Admin time to repair workstation
- Admin time to scan and remove virus from workstations, servers, backups, email, and other media

Corporate Security

- Virus attacks are trivial
- Cost of theft of biomedical research is the total expected returns from that research
  - which could be $300M for some
- Need to catalogue and cost out each and every risk
- Did I mention YOU need to maintain this?

IS Administrator View

- What is security
- Why do we care
- What do we do about it

What is security

- Authentication
- Encryption
- Permissions and Filters

What is security? Authentication

- Validate that you are who you say you are
- Access control
- Many methods
  - OS (WinNT, NDS)
  - Service (Kerberos, RADIUS)
  - Token (S/Key)

What is security? Encryption

- Secures channels from eavesdroppers
- Better encryption requires more CPU cycles
- Level required depends on the reason for use
  - time value of information
  - judgement call as what is needed
  - requirements will change with time

What is security? Permissions & Filters

- Column based Access Control Lists (ACL)
  - read, write, execute, delete by field
- Row based Access Control Lists
  - read, write, execute, delete by row
  - filters are SQL views with ACL's
- Detailed access rules to data

Why do we care?

- It is potentially a black hole for resources
- It is why Admin's get paid big bucks
  - They have access to the keys of the corporate kingdom
- It is an ongoing problem

What do we do about it?

- Control Physical Access
- Establish Policies and Procedures
- Control Network Access
- Control OS Access
- Control Application Access

Physical Access

- Review premises security
- Lock down workstations computers
- Restrict access to removable writable media
- Workstations should have no data stored on them
- Physically secure servers
- Secure removable media, especially backups

Policies and Procedures

- Password ageing, reuse, length, and complexity rules
- Sharing passwords, writing passwords down
- Users hate passwords
- Renaming accounts (administrator)
- Disabling unused accounts (guest)

Network Access

- Networks can be tapped
- Networks include the telephone switch
- Dial in access
- Internet access
  - use firewalls, proxy servers, router filters, network address translation, vpns, split level dns, and anything else you can think of
  - not a big risk, but a constant one
  - easiest for password cracking

Operating System Access

- Understand, intimately, the security structure of every OS you use (WinNT, NetWare, Linux, MacOS, OS/2, Win95, DOS, VMS, MVS, …)
- If you don't understand it and the person breaking in does, then you will be breached
- Use add on tools where appropriate (NDS on NT, or security analyzers)

Application Access

- Every application will have a distinct security model, understand it
- Where possible use integrated security
- E.g. SQL Server and WinNT
  - too many passwords becomes a security risk
- Where possible delegate

Tips and Tricks

- Use Roles to define sets of permissions
- Assign Users to a Role
- NEVER override security on a per user basis
- Use templates to setup Roles

IS Developer View

- Types of Security
- Amount of Work involved
- Different Security Models

What is Security?

- Security types
  - authentication
  - encryption
  - permissions and filters

Why Do Developers Care About Security?

- Often they don't
  - Which creates a problem!
- Developers are responsible for implementing security in the system
- Security is a lot of work
- Security certification requires extensive testing

What do Developers Do About Security?

- Design in Security from the Start
- Decide on a Security model
- Security Models to choose from
  - Access Control (weakest)
  - Application
  - File System
  - Database / Server (strongest)

Linux Security

- Securing a Linux system - overview
- Security principles
- Firewall strategies
- Setting up firewalls

Keeping the System Secure

- This is a full-time job, especially if the system is connected to the Internet
- Absolutely guard the root password, and change it from time to time
- If others need to administer parts of the system, set their privileges up with sudo
  - Only one person should use the root account for accountability

Network Security

- Problems associated with the network can come from the inside or outside
  - Can be malicious, accidental, or curiosity
- Should set up log files to catch suspicious activity and read them daily
- Port security is critical
  - Know all the ports and services on your system
  - Look for activity on unauthorized ports

Unauthorized Access

- Most TCP/IP services are accessible from any system unless restricted
  - NFS, NIS, SAMBA
  - HTTP, FTP, SSH
  - RLOGIN, RSH, TELNET
- Think who should access these and restrict access accordingly
  - Disable risky services and restrict allowed clients for the rest

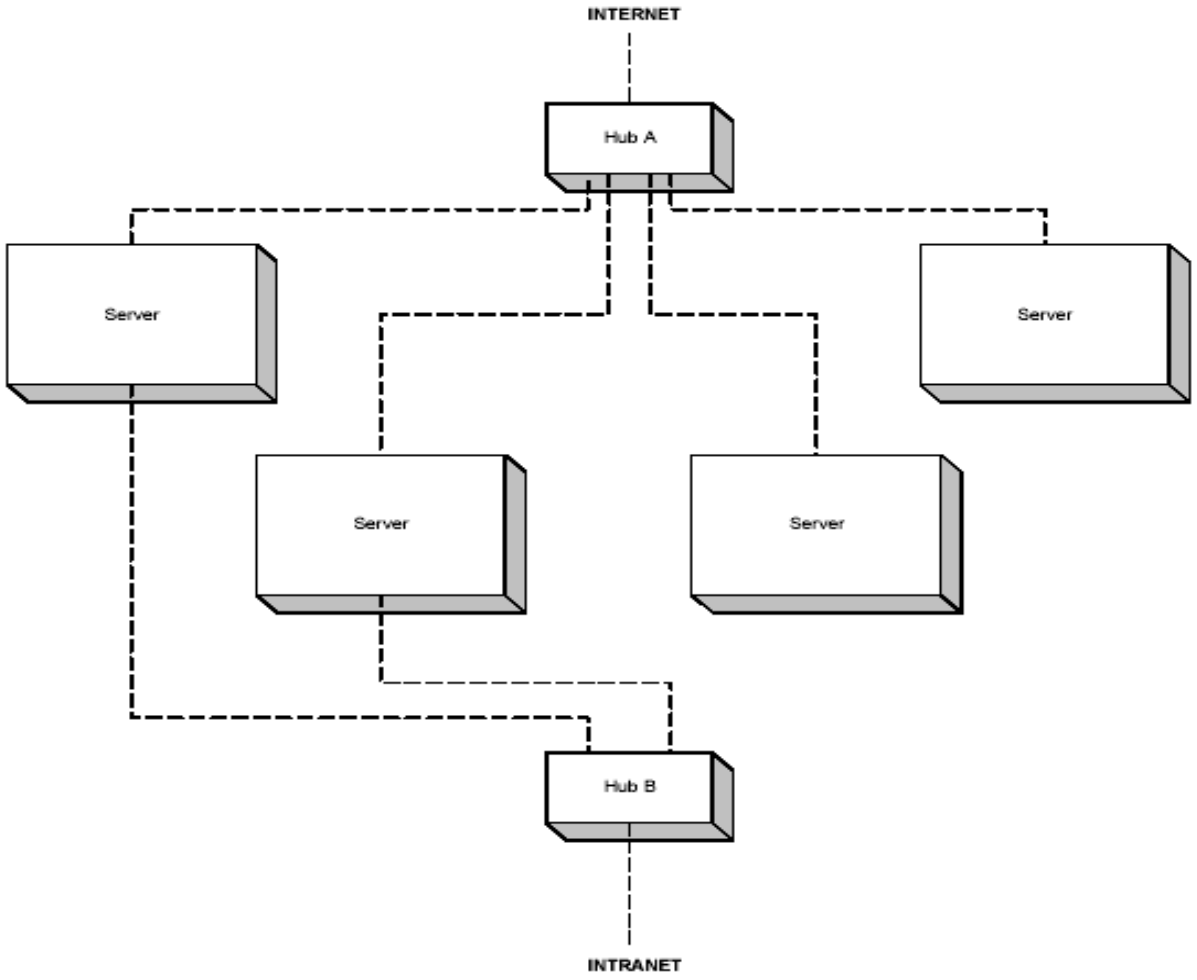
IP Firewalling

- Firewalls are effective in preventing unauthorized access, network layer denial of service, and IP spoofing attacks
- They do not help weaknesses in applications and eavesdropping
- Firewalls use secure and trusted machines between a private and a public network
  - Often using specialized hardware
- Simple firewalls can be added to clients

Firewall Functionality

- Firewall software are configured with rules
  - What happens with each network packet
  - Packets can pass, be blocked, or modified
  - Rules can handle both incoming and outgoing packets
- Network designed with firewalls, servers and client computers
  - To achieve reasonable security and access

Perimeter Network



Packet Filtering

- TCP/IP headers contain
  - Source/destination IP address
  - TCP/UDP source/destination port
  - ICMP message type
  - Encapsulated protocol information (TCP, UDP, ICMP or IP tunnel)
- Used to decide what do do with the packet
- Servers should at least block unused ports, in case firewall compromised

Linux Packet Filtering

- Built into kernel – very fast
- Kernel part called netfilter
  - nftables replaces parts after kernel 3.13
- Firewall client software called iptables or firewalld
  - firewalld can interface to iptables or nftables
- Can build very secure firewall using these
  - NT may be too insecure for a serious firewall
- Three tables (netfilter) : Filter, NAT, Mangle

Tables

- Filter
  - Default table
  - Used to DROP or ACCEPT packets based on content
  - Builtin chains are INPUT, FORWARD, OUTPUT
  - Holds user-defined chains
- NAT
  - translates source or destination fields
  - Builtin chains PREROUTING, OUTPUT, POSTROUTING
- Mangle
  - Used to alter TOS (type of service), TTL, MARK fields
  - Builtin chains PREROUTING and OUTPUT

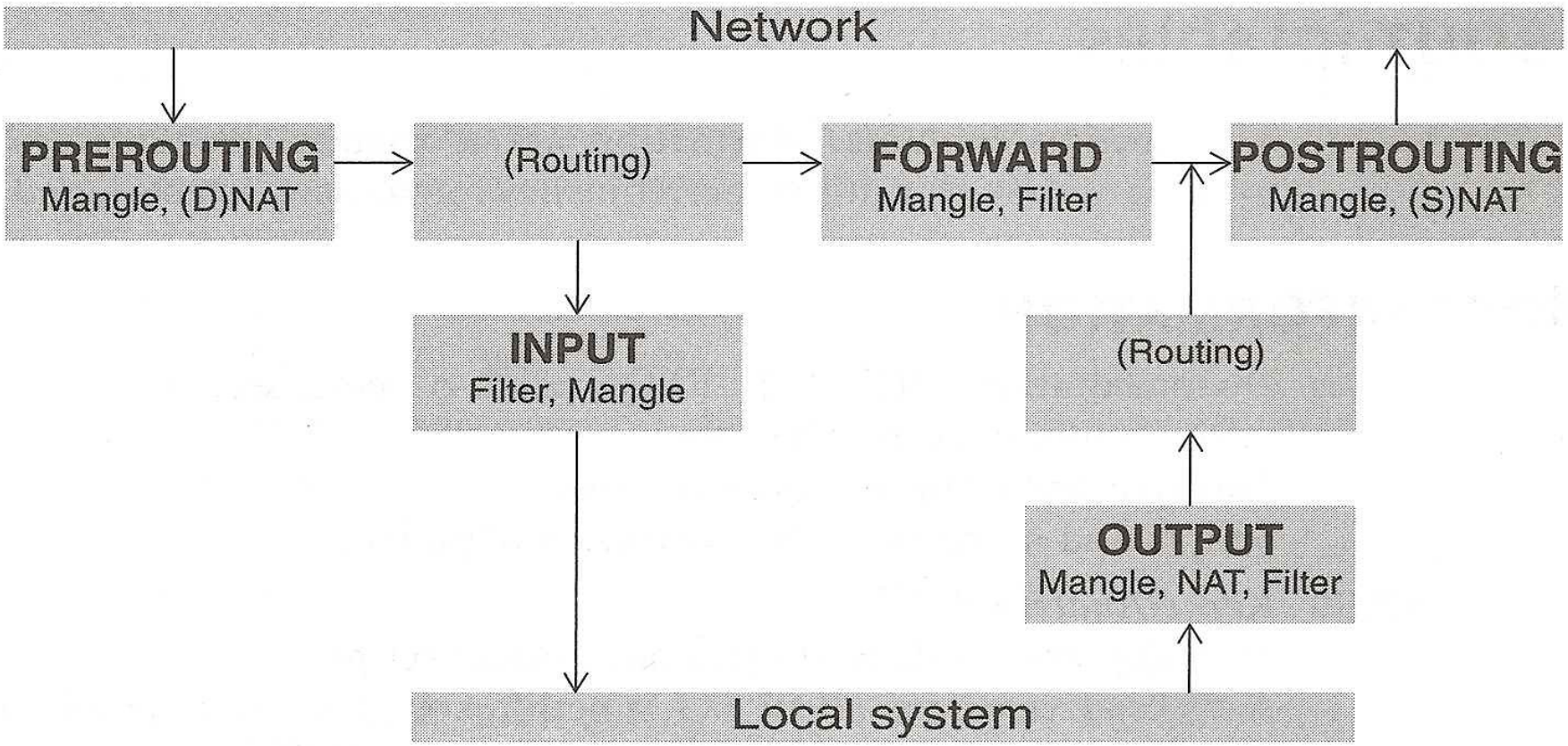
Types of NAT

- NAT: Network Address Translation table
  - used to translate source or destination fields for new connections
  - DNAT: destination NAT
    - alters destination IP of first inbound packet in connection to reroute to another host
    - used to send internet packets through firewall to server that handles that service (web, mail, etc.)
  - SNAT: source NAT
    - alters source IP of first outbound packet in connection so it appears to come from a fixed IP address
  - MASQUERADE: checks for IP address to apply to each packet such as comes from DHCP

Kernel Netfilter

- Packets go through one of 5 chains
  - INPUT, OUTPUT, FORWARD, PREROUTING, POSTROUTING (or user defined chains)
  - FORWARD is for routers
- Each chain is a set of rules
  - Can ACCEPT or DROP packet
  - Each rule has a pattern to match in the packet header – match processes the packet
  - If no rules match use the default chain policy
  - Can log results for later review
- iptables application allows creating, modifying, listing chains

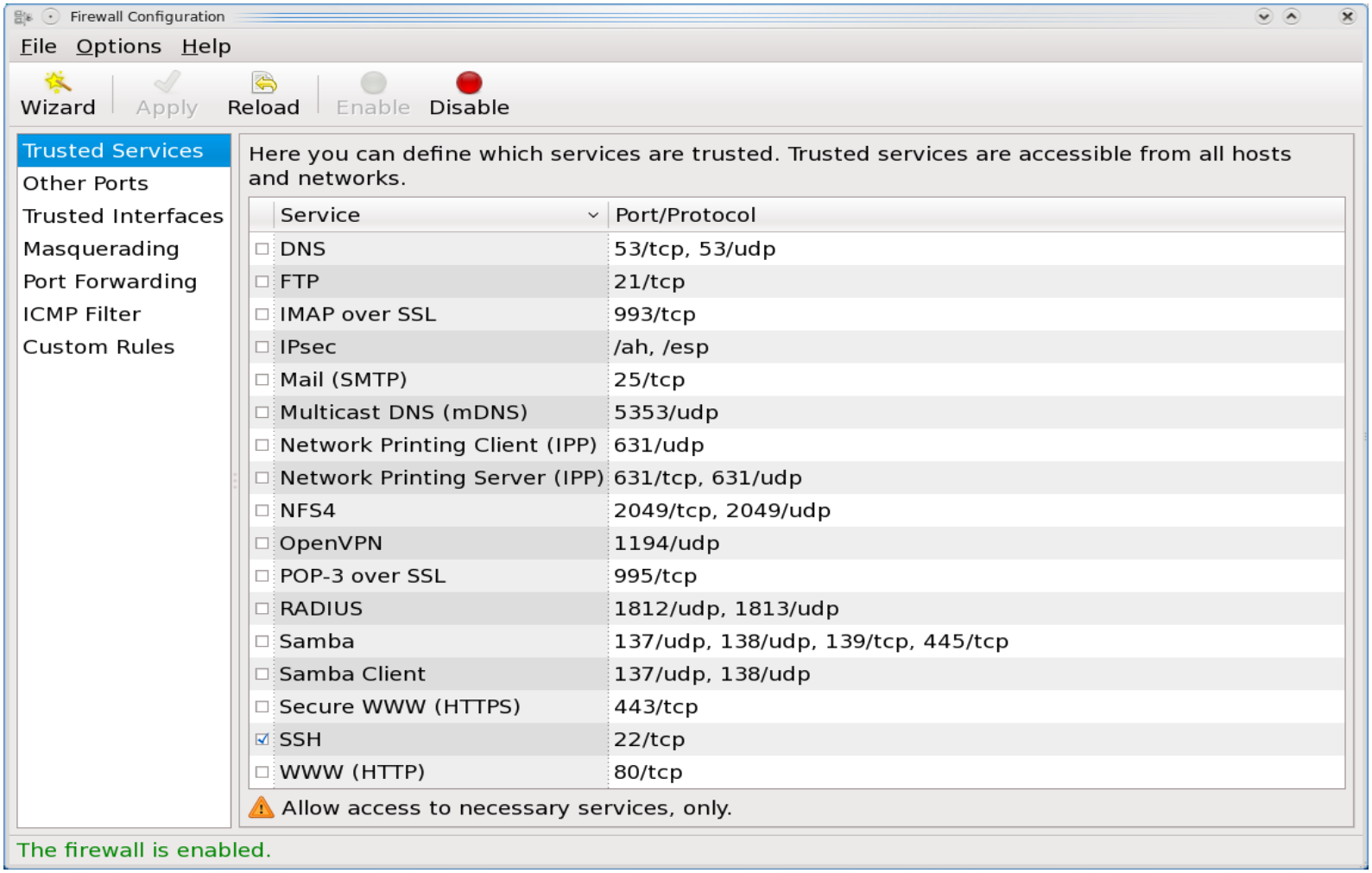
Filtering a Packet in the Kernel



Installing and Configuring iptables

- Install iptables or firewalld package
- Start service when system comes up
  - before network service
- Configuration
  - iptables requires a series of iptables commands to configure the rules
    - Can put into script which runs at boot time and call script from /etc/rc.d/rc.local
    - Can put into /etc/sysconfig/iptables file
      - written to by system-config-iptables and /sbin/service iptables save

GUI Configuring a Firewall: yum install firewall-config



iptables Operations on Chains

- Create new chain (-N)
- Delete empty chain (-X)
- Change policy for a built-in chain (-P)
- List rules in a chain (-L)
- Flush the rules out of a chain (-F)
- Zero the packet and byte counters on all rules in a chain (-Z)

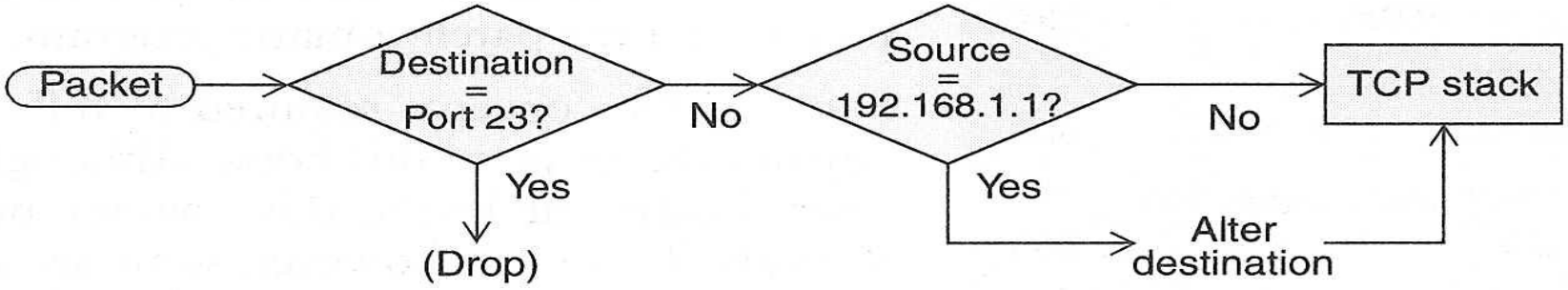
iptables Operations on Rules

- Append a new rule to a chain (-A)
- Insert new rule at some position in a chain (-I)
- Replace rule at some position in a chain (-R)
- Delete a rule at some position in a chain, or the first that matches (-D)

What Is a Rule?

- Each rule specifies conditions the packet must meet and what is done to it if it meets the conditions (called 'target')
  - E.g. drop all ICMP packets coming from 127.0.0.1
  - iptables -A INPUT -s 127.0.0.1 -p icmp -j DROP
- Then to delete this rule:
  - iptables -D INPUT 1
  - iptables -D INPUT -s 127.0.0.1 -p icmp -j DROP
- Consult one of the tutorials or howtos about some reasonable rule sets

Example of Rule



- First rule: drop packets with destination port 23 (telnet)
- Second rule: if packet source is 192.168.1.1, alter its destination

Intrusion Detection

- Two approaches
  - host-based and network-based
- Both look for specific patterns indicating suspicious intent
  - Attack signatures
  - Host-based looks for attack signatures in log files
  - Network-based looks for patterns in network traffic
- Two techniques complement each other

Network-Based Detection

- Use raw network packets as data source
- Uses an interface configured in promiscuous mode to look at all network traffic
- Packets checked for
  - Pattern, expression of bytecode matching
  - Frequency of threshold crossing
  - Port signatures
  - Header condition matching

Host-Based Detection

- Software logs the network requests and activities
- Logs reviewed for suspicious activities
  - Login failures, rejected packets from firewall, rejected service requests, etc.
- Single entry may not be problem, look for patterns
  - Several failed attempts from a given IP
  - Port scans

Intrusion-Detection Tools

- tcpdump
  - Can write filters for patterns in tcp packets
    - Available for Win32 as windump
- snort
  - Custom filters for intrusion detection
- snortsnarf
  - Helps analyze snort output files
- Network Flight Recorder (NFR)
  - Network based commercial product

Summary: Security

- Note that security is a big subject and firewalls are a small (but important part)
- The iptables utility creates firewalls intended to prevent unauthorized access to a system or network
- Chains of rules are collected in three tables
  - Filter, NAT, Mangle
  - Filter is default table used to DROP or ACCEPT packets based on content

Chapter 26: Apache (httpd): Setting Up a Web Server

- Apache still is the most popular web server
  - Active sites: Apache 25%, nginx 20%, Google 10%, Cloudflare 9%, MS 4% other 25%)
  - Total sites: nginx 35%, Apache 26%, MS 7%
    - Netcraft survey, February 2021
- It is a good choice for serving static web pages
  - or being the front end for a load-balancing
- Configure using the /etc/httpd/conf/httpd.conf file

Installation

- httpd, apr (Apache portable runtime), apr-util
- Configure to start when entering multiuser mode
  - systemctl enable httpd.service
- Can also install optional packages
  - httpd-manual, system-config-httpd, webalizer, mod_perl, mod_python, mod_ssl, php, mrtg (traffic monitoring), net-snmp (required for MRTG), net-snmp-utils

httpd.conf

- Configuration directives grouped into three main sections:
  - Operation of the Apache server process as a whole (the 'global environment')
  - Parameters of the 'main' or 'default' server
    - for requests that aren't handled by a virtual host
    - default values for the settings of all virtual hosts.
  - Settings for virtual hosts
    - for requests sent to different IP addresses or hostnames handled by the same Apache server

Section 1: Global Environment

```
# ServerType is either inetd, or standalone.
ServerType standalone
# ServerRoot: The top of the directory tree under which the server's
# configuration, error, and log files are kept.
ServerRoot "/etc/httpd"
 # KeepAlive: Whether or not to allow persistent connections
KeepAlive On
# Number of servers to start initially
StartServers 8
# Limit on total number of servers running
MaxClients 150
#bind Apache to specific IP addresses/ports
Listen 80
# BindAddress: You can support virtual hosts with this option
#BindAddress *
```

Global Evironment

```
# Dynamic Shared Object (DSO) Suppor
LoadModule jserv_module      modules/mod_jserv.so
LoadModule vhost_alias_module modules/mod_vhost_alias.so
LoadModule env_module         modules/mod_env.so
LoadModule config_log_module  modules/mod_log_config.so
LoadModule agent_log_module   modules/mod_log_agent.so
 …
AddModule mod_jserv.c
AddModule mod_vhost_alias.c
AddModule mod_env.c
AddModule mod_log_config.c
AddModule mod_log_agent.c
 …
```

Section 2: Main Server Config.

```
# Port: The port to which the standalone server listens. For
# ports < 1023, you will need httpd to be run as root initially.
Port 80
# If you wish httpd to run as a different user or group, you must run
# httpd as root initially and it will switch.
User apache
Group apache
# ServerName: allows you to set a host name which is sent back to clients
#ServerName localhost
# DocumentRoot: The directory out of which you will serve your
# documents
DocumentRoot "/var/www/html"
```

Directory Permissions

- Each directory to which Apache has access can be configured
  - which services and features are allowed and/or disabled in that directory (and its subdirectories)
- If something does not work, check permissions

Some Directory Options

- FollowSymLinks - follow the symbolic links from this directory
- SymLinksIfOwnerMatch - follow symbolic links if target owner is same as link owner
- ExecCGI - executable scripts are allowed in this directory
- Includes - server side includes are allowed in this directory
- Indexes - server will generate directory listing if directory does not contain a title page

Main Server, continued

```
<Directory "/var/www/html">
    Options Indexes Includes FollowSymLinks

#
# This controls which options the .htaccess files in directories can
# override. Can also be "All", or any combination of "Options", "FileInfo",
# "AuthConfig", and "Limit"
#
    AllowOverride None

# Controls who can get stuff from this server.
Order allow,deny
    Allow from all
</Directory>
```

Main Server, continued

```
# UserDir: The name of the directory which is appended onto a user's home
# directory if a ~user request is received.
UserDir public_html
# Control access to UserDir directories.
<Directory /home/*/public_html>
    AllowOverride FileInfo AuthConfig Limit
    Options MultiViews Indexes SymLinksIfOwnerMatch ExecCGI
    <Limit GET POST OPTIONS PROPFIND>
        Order allow,deny
        Allow from all
    </Limit>
    <Limit DELETE PATCH PROPPATCH MKCOL COPY MOVE LOCK UNLOCK>
        Order deny,allow
        Deny from all
    </Limit>
</Directory>
```

Main Server, Continued

```
# DirectoryIndex: Name of the file or files to use as a pre-written HTML
# directory index.  Separate multiple entries with spaces.
#
DirectoryIndex index.html index.htm index.shtml index.php index.php4 index.php3 index.cgi
#
# AccessFileName: The name of the file to look for in each directory
# for access control information.
#
AccessFileName .htaccess
# prevent .htaccess files from being served
<Files ~ "^\.ht">
    Order allow,deny
    Deny from all
</Files>
```

Main Server, continued

```
ScriptAlias /cgi-bin/ "/var/www/cgi-bin/"
#
# "/var/www/cgi-bin" should be changed to whatever your ScriptAliased
# CGI directory exists, if you have that configured.
#
<Directory "/var/www/cgi-bin">
    AllowOverride None
    Options ExecCGI
    Order allow,deny
    Allow from all
</Directory>
```

Main Server, continued

```
# AddHandler: allows you to map certain file extensions to "handlers",
# To use CGI scripts:
#
AddHandler cgi-script .cgi .pl
#
# To use server-parsed HTML files
#
AddType text/html .shtml
AddHandler server-parsed .shtml
```

Main Server, continued

```
# Allow http put (such as Netscape Gold's publish feature)
# Use htpasswd to generate /etc/httpd/conf/passwd.
#Alias /upload /tmp
#<Location /upload>
#    EnablePut On
#    AuthType Basic
#    AuthName Temporary
#    AuthUserFile /etc/httpd/conf/passwd
#    EnableDelete Off
#    umask 007
#    <Limit PUT>
#            require valid-user
#    </Limit>
#</Location>
```

Section 3: Virtual Hosts

- For multiple domains/hostnames on your machine
  - Setup VirtualHost containers for them
- See the documentation at http://www.apache.org/docs/vhosts/ for further details
- Use the command line option '-S' to verify your virtual host configuration

Virtual Hosts

```
# If you want to use name-based virtual hosts you need to define at
# least one IP address (and port number) for them.
#
#NameVirtualHost 12.34.56.78:80
 #
# Almost any Apache directive may go into a VirtualHost container.
#
#<VirtualHost ip.address.of.host.some_domain.com>
#    ServerAdmin webmaster@host.some_domain.com
#    DocumentRoot /www/docs/host.some_domain.com
#    ServerName host.some_domain.com
#    ErrorLog logs/host.some_domain.com-error_log
#    CustomLog logs/host.some_domain.com-access_log common
#</VirtualHost>
```

Authentication and Access

- Access control can be based on hostname, IP address, or user name/password
- Secure protocols add encryption and digital signatures (S-HTTP or SSL)
- Unless you use cryptography, passwords sent in cleartext
  - Don’t use same user name/password as real accounts!!!

Access control based on IP or hostname

- Add to Limit section for directories:

```
<Directory /local/web/private>
  <Limit get>
    order deny, allow
    deny from all
    allow from .host.domain1
    allow from .host.domain2
    allow from 192.168.2.2
  </Limit>
</Directory>
```

Access Control Based on User/Password

- Create password file and add users
- htpasswd handles simple password files
- Then add options
  - AuthType Basic
  - AuthUserFile /etc/httpd/conf/passwd
  - AuthGroupFile /etc/httpd/conf/group
- Restrictions can be in .htaccess files as well
  - Placed in each directory you want to control

webalizer: Analyze Web Traffic

- Creates directory at /var/www/usage and cron file
- Generates usage data daily and puts in usage directory
  - Can view at http://host/usage/
- Can change default behaviour by editing /etc/webalizer.conf file
  - See man page

MRTG: Monitor Traffic Loads

- Multi Router Traffic Grapher (MRTG)
  - Open source application that graphs statistics from SNMP
- Simple Network Management Protocol (SNMP)
  - Used by high-end routers and switches, printers, wireless access points
- Can view reports at http://host/mrtg
- See mrtg man page

Summary: Apache

- Popular, robust, extensible
- Content typically in /var/www/html
  - called document root
- Configuration directives in /etc/httpd/conf/httpd.conf control how Apache functions
- Can restrict access to web pages, redirect requests, define virtual hosts, run CGI programs, and use SSL